

**MEDICARE CONNECT (PTY) LTD
TABLETOP SIMULATION REPORT**

Scenario: Phishing Attack Leading to Patient Communication Compromise

Classification : Confidential
Version : 1.0
Simulation Date : March 2026
Facilitator : Patrick Mohlala, GRC Analyst
Participants : IR Team (simulated)

1. PURPOSE OF THE EXERCISE

A tabletop exercise tests the Incident Response Plan without involving live systems. Participants walk through a realistic scenario and discuss actions at each stage. The goal is to find gaps in the plan before a real incident does.

2. SCENARIO – OPERATION PATIENT ZERO

It is Tuesday at 09:15.

A receptionist at MediCare Connect receives an email appearing to come from Discovery Health requesting urgent update of patient billing details via a link.

She clicks the link and enters her Microsoft 365 login credentials on what appears to be a legitimate page.

At 14:30 the same day the IT Manager receives an alert from Microsoft 365 showing a login to her account from an IP address in Romania.

By 14:45 the IT Manager discovers the attacker has been browsing patient referral emails and exported a contact list of 340 patients.

At 15:00 the IT Manager calls the GRC Analyst.

3. INJECT TIMELINE AND FINDINGS

Inject 1 at 09:15 Tuesday

Event : Receptionist clicks phishing link and enters credentials.
Question : Does anyone notice at this point?
Finding : No. No MFA and no real-time monitoring in place.

Inject 2 at 14:30 Tuesday

Event : IT Manager receives foreign login alert.
Question : What is the first action?
Response : Revoke session and reset password immediately.
Finding : Correct action. However no MFA meant the attacker had full access for about 5 hours undetected.

Inject 3 at 14:45 Tuesday

Event : Patient contact data export discovered.
Question : Is this a POPIA reportable breach?
Response : Yes. Patient contact details are personal information.
Finding : Correctly identified The 72-hour clock starts. Deadline: Thursday 14:45.

Inject 4 at 15:00 Tuesday

Event : IR team assembled.
Question : Who contacts the CEO?
Response : IT Manager.
Finding : Correct per RACI model.

Inject 5 at 15:30 Tuesday

Event : CEO asks whether patients must be told.
Question : What is the answer and why?
Response : Yes. Patient contact details were accessed without authorisation.
Finding : Correctly identified. Patient notification required.

Inject 6 at Wednesday 09:00

Event: Legal counsel asks for evidence log.
Question: Do we have a documented chain of custody?
Response: Timeline exists but not in formal chain-of-custody format.
Finding: GAP. Evidence log format needs improvement.

Inject 7 at Wednesday 14:00

Event : Preparing Information Regulator notification.
Question : Has Form 4 been submitted?
Response : Not yet. Still drafting.
Finding : GAP. About 30 hours elapsed. 42 hours remaining. Process too slow under pressure.

Inject 8 at Thursday 10:00

Event : A patient calls asking why their email was shared.
Question : Who handles this call and what do they say?
Response : Receptionist takes call and does not know what to say.
Finding : GAP. Front desk not briefed. No escalation script prepared.

4. WHAT WORKED WELL

- Incident correctly classified as Tier 1
- POPIA reportability correctly assessed
- CEO notification followed correct channel
- Patient notification requirement identified
- Credential revocation done immediately

5. GAPS IDENTIFIED

GAP 1 : No MFA allowed ~5 hours undetected access to patient communications
Severity : Critical
Action : Enable MFA immediately (already in Month 1 remediation plan from Projects 1 and 2)

GAP 2 : Evidence log not in chain-of-custody format acceptable to regulators
Severity : High
Action : Create formal evidence log template with chain-of-custody fields

GAP 3 : Form 4 notification took too long to prepare under pressure
Severity : High
Action : Pre-populate Form 4 with company details so only incident-specific fields need completing
During an event

GAP 4 : Front desk staff not briefed on patient calls during an incident
Severity : Medium
Action : Create call-handling script for front desk and include in awareness training

GAP 5 : No DLP or monitoring detected bulk patient data export for 5 hours
Severity : High
Action : Enable Microsoft Purview DLP policies to alert on bulk data exports

6. CORRECTIVE ACTION PLAN

ACTION	OWNER	PRIORITY	DEADLINE
Enable MFA on Microsoft 365	IT Manager	Critical	Month 1
Create evidence log template	GRC Analyst	High	Month 1
Pre-populate Form 4 template	Information Officer	High	Month 1
Create front desk call script	GRC Analyst	Medium	Month 2
Enable Microsoft Purview DLP	IT Manager	High	Month 3

7. OVERALL ASSESSMENT

The IR plan provided a workable framework, but the simulation exposed five gaps that would have caused problems in a real event.

Most significant finding: absence of MFA created a multi-hour window of undetected access to patient communications. This reinforces RSK-003 from the risk register as the highest-priority technical control.

POPIA notification was correctly identified but too slow in practice. Pre-prepared templates and clearer ownership address this.

SIMULATION VERDICT: PARTIALLY READY

Five corrective actions required before the plan is considered operationally effective.

Next tabletop exercise recommended: Ransomware scenario – September 2026.

Document Control

Prepared by: Patrick Mohlala, GRC Analyst

Date: March 2026

Version: 1.0

Distribution: CEO, IT Manager, Information Officer